

Informe de Incidente: Vulnerabilidad por Inyección SQL

1. Descripción del Incidente

Se realizó una prueba en la aplicación web "Damn Vulnerable Web Application (DVWA)" para demostrar una vulnerabilidad por inyección SQL. Esta vulnerabilidad permite acceder a datos no autorizados en la base de datos al inyectar comandos SQL maliciosos en los campos de entrada.

2. Pruebas Realizadas

Se utilizó el parámetro id en la URL para introducir una inyección SQL. La consulta ejecutada fue:

```
?id=1'+OR+'1'='1
```

Esta consulta siempre evalúa como verdadera (1=1), lo que permitió que el sistema devolviera información de múltiples usuarios almacenados en la base de datos.

3. Resultados Obtenidos

Como se observa en la captura de pantalla, los datos de varios usuarios fueron expuestos:

- ID: 1, Nombre: admin
- ID: 1, Nombre: Gordon Brown
- ID: 1, Nombre: Hack Me
- ID: 1, Nombre: Pablo Picasso
- ID: 1, Nombre: Bob Smith

4. Impacto

La explotación de esta vulnerabilidad puede permitir:

- Acceso no autorizado a datos sensibles.
- Modificación o eliminación de datos en la base de datos.
- Compromiso total del sistema si se encadenan con otras vulnerabilidades.

5. Mitigación

Para prevenir esta vulnerabilidad, se recomienda:

1. Validación de Entradas: Utilizar consultas preparadas (prepared statements) con parámetros.
2. Principio de Mínimos Privilegios: Limitar los privilegios de la cuenta de la base de datos.
3. Escaneo de Seguridad: Realizar pruebas de seguridad regulares.
4. Actualización de Software: Asegurarse de que los frameworks y librerías utilizados estén actualizados.

6. Referencias

- OWASP: SQL Injection: https://owasp.org/www-community/attacks/SQL_Injection
- Guía de Prevención de Inyección SQL: <https://bobby-tables.com/>

Captura de Pantalla de la Prueba

